BOTIUM TOYS

Revisione dei controlli di sicurezza e della conformità

Case study di portfolio · organizzazione fittizia · valutazione basata su documenti

8/10	5 / 14	7 / 14	3 / 12
Gravità del rischio	**Controlli**	**Controlli**	**Conformità**
Alta	In atto	Non in atto	In atto

NOTA SUL PORTFOLIO

Questo è un case study didattico basato sui materiali Botium Toys del Google Cybersecurity Certificate. Non ho testato un ambiente reale, non ho verificato configurazioni e non ho eseguito una valutazione formale PCI DSS, GDPR o SOC.

Ambito

Controllo degli accessi / riservatezza dei dati / ripristino / monitoraggio

01 Sintesi

Botium Toys parte già da una base di sicurezza utile. Un firewall filtra il traffico, l'antivirus è monitorato, ci sono controlli sull'integrità dei dati e uffici, negozio e magazzino hanno serrature, telecamere e protezione antincendio. Il problema è che questi controlli sono sbilanciati. L'azienda protegge meglio il perimetro e i locali fisici di quanto decida chi può vedere i dati sensibili, protegga quei dati una volta archiviati e si riprenda quando qualcosa va storto.

Il punto più grave è l'accesso. Tutti i dipendenti possono raggiungere i dati archiviati internamente, mentre privilegio minimo e separazione dei compiti non sono applicati. La stessa debolezza ricompare nei controlli PCI DSS e in quelli legati a SOC, perché i dati dei clienti, dei titolari di carta e i dati PII/SPII rientrano nell'analisi. Manca anche la cifratura, quindi il problema di riservatezza non riguarda solo chi può accedere ai dati, ma anche quanto sono protetti i dati stessi.

Il ripristino è l'altra grande debolezza. Non esistono backup dei dati critici né un piano di disaster recovery. Anche il rilevamento è incompleto: firewall e antivirus fanno da base, ma non c'è un IDS e i sistemi legacy vengono controllati senza una scadenza regolare e senza una procedura chiara di intervento.

Ho mantenuto il punteggio di rischio 8/10 dello scenario. Le mie prime priorità sarebbero limitare l'accesso alle informazioni sensibili, introdurre la cifratura, creare backup e un piano di ripristino, rafforzare i controlli sulle password e migliorare il monitoraggio. I controlli che già funzionano vanno mantenuti e usati come base, non sostituiti tanto per farlo.

Cosa funziona già secondo i materiali di partenza

- Le regole del firewall risultano definite in modo appropriato e attive.
- L'antivirus è installato e monitorato con regolarità.
- I controlli sull'integrità dei dati sono presenti.
- Esiste un piano di notifica delle violazioni entro 72 ore per i clienti dell'Unione Europea.
- Le procedure sulla privacy sono documentate e applicate dal personale interessato.
- La sicurezza fisica comprende serrature, telecamere e sistemi di rilevazione e prevenzione incendi.

02 Ambito e metodo

La valutazione copre il programma di sicurezza descritto nel caso: dispositivi dei dipendenti, rete interna, sistemi aziendali, dati archiviati, servizi di ecommerce e magazzino, sistemi legacy e sede fisica. I materiali di partenza includono anche beni come le scorte del negozio e le attrezzature in sede, perché perderli o non poterli usare può bloccare l'attività.

Obiettivi della valutazione

- Individuare quali controlli sono già presenti e quali mancano o sono incompleti.
- Collegare le lacune dei controlli alle pratiche PCI DSS, GDPR e SOC usate nell'esercizio.
- Trasformare la checklist in un ordine di interventi concreto, su cui un responsabile possa agire.

Come ho valutato i controlli

L'esercizio originale funziona soprattutto con Sì/No. Per la versione da portfolio ho aggiunto un terzo stato, Parzialmente in atto, dove una risposta binaria nasconderebbe informazioni utili. Due esempi sono la policy delle password, che esiste ma è debole, e il monitoraggio dei sistemi legacy, che esiste ma non ha una scadenza né una procedura chiara di intervento.

Le priorità sono il mio contributo da analista, non punteggi presi dal materiale del corso. Servono a mostrare quali lacune affronterei per prime in base alle prove dello scenario. Non ho aggiunto fatti tecnici che non fossero nei documenti forniti.

03 Panoramica del rischio

8/10	Alta	Alta	Parziale
Rischio complessivo	**Esposizione dei dati**	**Lacuna di ripristino**	**Rilevamento**
Valutazione della fonte	Accessi + cifratura	Niente backup / DR	Firewall + antivirus, nessun IDS

Cosa fa salire il rischio

- Tutti possono accedere ai dati archiviati internamente; mancano privilegio minimo e separazione dei compiti.
- Nello scenario i dati dei titolari di carta non sono protetti dalla cifratura.
- I dati critici non hanno backup e non c'è un piano di disaster recovery.
- Non c'è un IDS, quindi manca il rilevamento a livello di rete.
- I requisiti delle password sono deboli e non vengono applicati in modo centralizzato.
- I sistemi legacy sono gestiti a mano, ma la scadenza e la procedura di intervento non sono chiare.

Lo scenario descrive come medio l'impatto della perdita di un singolo bene, soprattutto perché il quadro dei beni è incompleto. L'esposizione complessiva è più alta: le informazioni sensibili possono essere accessibili a troppe persone, e la mancanza di controlli di ripristino può trasformare un incidente o un guasto in un'interruzione più lunga dell'attività.

04 Categorie di controllo e piccolo glossario

Ho mantenuto la terminologia del documento di riferimento sulle categorie di controllo. La categoria dice dove si colloca un controllo, il tipo dice a cosa serve. Sono idee collegate ma non sono la stessa cosa.

CATEGORIA	SIGNIFICATO IN PAROLE SEMPLICI	ESEMPI IN QUESTO CASO
Amministrativo / Gestionale	Politiche, responsabilità e pratiche di gestione che determinano come le persone trattano la sicurezza e i dati.	Privilegio minimo, policy delle password, separazione dei compiti, disaster recovery
Tecnico	Tecnologia usata per proteggere sistemi, reti, account o dati.	Firewall, IDS, cifratura, backup, antivirus, gestione delle password
Fisico	Misure che proteggono edifici, attrezzature e altri beni fisici da accessi non autorizzati o danni.	Serrature, telecamere, rilevazione e prevenzione incendi

TIPO	A COSA SERVE	ESEMPIO
Preventivo	Ridurre la probabilità che un incidente accada.	Privilegio minimo, firewall, policy delle password
Di rilevamento	Mostrare che un'attività sospetta o un incidente è in corso o è già avvenuto.	IDS, telecamere
Correttivo	Aiutare a ripristinare dati, sistemi o attività dopo un evento.	Backup, disaster recovery
Deterrente	Scoraggiare un attacco o rendere un bene meno interessante per chi attacca.	Serrature; il riferimento del corso classifica qui anche la cifratura

Nota: nella pratica alcuni team di sicurezza possono classificare i singoli controlli in modo diverso, a seconda del contesto. Questo report mantiene le etichette del riferimento del corso, per restare coerente con il materiale su cui si basa il case study.

05 Valutazione dei controlli

Le domande sono scritte in modo da includere lo scopo di ogni controllo, così la tabella si capisce anche da sola. Prove e raccomandazioni restano vicine alle parole del caso, senza supporre dettagli che non sono stati forniti.

CONTROLLO	CATEGORIA / TIPO	DOMANDA DI VALUTAZIONE	STATO	PROVE	AZIONE CONSIGLIATA	PRIORITÀ
Privilegio minimo	Amministrativo / Preventivo	I dipendenti possono raggiungere solo i dati che servono davvero al loro lavoro, in particolare quelli di clienti, pagamenti e altri dati sensibili?	**Non in atto**	Tutti i dipendenti hanno accesso ai dati archiviati internamente e potrebbero raggiungere i dati dei titolari di carta e i PII/SPII.	Limitare l'accesso in base al ruolo e alla necessità di lavoro, e rivedere i permessi con regolarità.	**Critica**
Piani di disaster recovery	Amministrativo / Correttivo	Se si perde un sistema o un insieme di dati importante, esiste un piano scritto per ripristinare le attività critiche?	**Non in atto**	Non esiste alcun piano di disaster recovery.	Documentare responsabilità e procedure di ripristino per i sistemi e i dati critici.	**Critica**
Policy delle password	Amministrativo / Preventivo	La policy delle password fissa requisiti minimi ragionevoli e viene davvero applicata?	**Parzialmente in atto**	Una policy esiste, ma lo scenario descrive i suoi requisiti come solo nominali e inferiori al minimo atteso.	Rafforzare la policy e applicarla tramite una gestione centralizzata delle password.	**Alta**
Separazione dei compiti	Amministrativo / Preventivo	Le responsabilità delicate sono divise, così che una sola persona non controlli compiti incompatibili tra loro?	**Non in atto**	Il controllo non c'è. L'esempio del corso segnala inoltre che il CEO gestisce le operazioni quotidiane e il payroll.	Separare i compiti incompatibili e aggiungere un'approvazione indipendente dove serve.	**Alta**
Firewall	Tecnico / Preventivo	Il traffico di rete indesiderato viene filtrato con un insieme di regole definito in modo appropriato?	**In atto**	Il firewall blocca il traffico in base a un insieme di regole di sicurezza definito in modo appropriato.	Mantenere il firewall e rivedere le regole quando l'ambiente cambia.	**Mantenere**
Sistema di rilevamento delle intrusioni (IDS)	Tecnico / Di rilevamento	Esiste un controllo di rete in grado di segnalare attività anomale o potenzialmente dannose?	**Non in atto**	Il reparto IT non ha installato un IDS.	Installare un IDS e stabilire chi esamina, inoltra e documenta gli avvisi.	**Alta**
Backup	Tecnico / Correttivo	I dati critici hanno un backup che permetta di ripristinarli dopo una perdita, un danneggiamento o un incidente?	**Non in atto**	L'azienda non ha backup dei dati critici.	Creare backup regolari e documentare la procedura di ripristino.	**Critica**
Software antivirus	Tecnico / Correttivo	L'antivirus è installato e monitorato sui sistemi coperti dallo scenario?	**In atto**	L'antivirus è installato e monitorato regolarmente dal reparto IT.	Mantenere il monitoraggio e tenere il controllo operativo.	**Mantenere**
Monitoraggio dei sistemi legacy	Tecnico / Preventivo	I sistemi legacy vengono controllati con una scadenza regolare e con un processo chiaro di intervento quando si trova un problema?	**Parzialmente in atto**	I sistemi legacy sono monitorati e mantenuti, ma non c'è una scadenza regolare e i metodi di intervento non sono chiari.	Fissare un calendario di manutenzione e documentare il processo di intervento.	**Alta**
Cifratura	Tecnico / Deterrente*	Le informazioni sensibili e quelle dei titolari di carta sono protette con la cifratura, come richiesto dal caso?	**Non in atto**	Al momento la cifratura non viene usata per i dati delle carte di credito dei clienti.	Introdurre la cifratura per i dati sensibili e dei titolari di carta nei punti in cui vengono trattati.	**Critica**
Sistema di gestione delle password	Tecnico / Preventivo	Esiste un sistema centralizzato che supporti e applichi la policy delle password?	**Non in atto**	Non è presente alcun sistema centralizzato di gestione delle password.	Introdurre una gestione centralizzata delle password che applichi la policy approvata.	**Alta**

CONTROLLO	CATEGORIA / TIPO	DOMANDA DI VALUTAZIONE	STATO	PROVE	AZIONE CONSIGLIATA	PRIORITÀ
Serrature	Fisico / Deterrente + Preventivo	Uffici, negozio e magazzino sono protetti da ingressi fisici non autorizzati?	**In atto**	La sede fisica ha serrature sufficienti.	Mantenere le serrature e includerle nei controlli periodici di sicurezza fisica.	**Mantenere**
Videosorveglianza	Fisico / Preventivo + Di rilevamento	Le telecamere sono installate e funzionanti nella sede fisica?	**In atto**	Le telecamere sono installate e funzionano.	Mantenere la copertura e verificare che il sistema resti operativo.	**Mantenere**
Rilevazione / prevenzione incendi	Fisico / Di rilevamento + Preventivo	I sistemi di rilevazione e prevenzione incendi funzionano nella sede fisica?	**In atto**	La sede ha sistemi di rilevazione e prevenzione incendi funzionanti.	Mantenere e collaudare i sistemi esistenti.	**Mantenere**

** La cifratura è indicata come Deterrente perché così la classifica il riferimento del corso.*

06 Valutazione della conformità

Questa sezione verifica solo le pratiche elencate nell'esercizio. Non va letta come una certificazione formale né come un parere legale. Le parole qui sotto sono volutamente pratiche: ogni domanda dice cosa ho cercato, e le prove spiegano perché ho scelto quello stato.

AREA	FOCUS	DOMANDA DI VALUTAZIONE	STATO	PROVE	AZIONE CONSIGLIATA	PRIORITÀ
PCI DSS: accesso	Accesso autorizzato ai dati dei titolari di carta	Le informazioni dei titolari di carta sono limitate al personale che ne ha davvero bisogno per lavorare?	**Non in atto**	Tutti i dipendenti hanno accesso ai dati interni, che possono includere informazioni dei titolari di carta.	Applicare il privilegio minimo e limitazioni di accesso basate sul ruolo per i dati di pagamento.	**Critica**
PCI DSS: ambiente	Ambiente sicuro per i dati dei titolari di carta	I dati di pagamento sono trattati in un ambiente con controlli di accesso e protezioni di riservatezza adeguati?	**Non in atto**	I dati dei titolari di carta non sono cifrati e l'accesso ai dati interni è troppo ampio.	Limitare l'accesso e aggiungere la cifratura attorno all'ambiente dei dati dei titolari di carta.	**Critica**
PCI DSS: cifratura	Procedure di cifratura	Si usano procedure di cifratura per proteggere i dati dei titolari di carta nei punti di archiviazione, elaborazione e trasmissione?	**Non in atto**	Al momento l'azienda non usa la cifratura per le informazioni finanziarie dei clienti.	Introdurre procedure di cifratura in tutti i punti in cui passano i dati di pagamento.	**Critica**
PCI DSS: password	Gestione sicura delle password	I requisiti delle password sono abbastanza forti da ridurre il rischio di account compromessi e vengono applicati in modo centralizzato?	**Parzialmente in atto**	Esiste una policy delle password, ma è debole e non c'è un sistema centralizzato di gestione.	Rafforzare i requisiti delle password e applicarli in modo centralizzato.	**Alta**
GDPR: sicurezza dei dati	Privacy e sicurezza dei dati dei clienti UE	I dati personali dei clienti UE sono mantenuti riservati e protetti con i controlli descritti nel caso?	**Non in atto**	Lo scenario individua lacune di riservatezza, tra cui un accesso troppo ampio e l'assenza di cifratura.	Restringere l'accesso ai dati personali e migliorare i controlli di riservatezza.	**Critica**
GDPR: notifica delle violazioni	Piano di notifica entro 72 ore	Esiste un piano documentato per avvisare i clienti UE entro 72 ore se i loro dati vengono compromessi, come richiesto dall'esercizio?	**In atto**	Lo scenario dice che un piano di notifica entro 72 ore è in vigore.	Mantenere il processo e tenere la documentazione utilizzabile.	**Mantenere**
GDPR: classificazione	Inventario e classificazione dei dati	I dati sono sia censiti sia classificati, così che l'organizzazione sappia cosa possiede e quanto è sensibile?	**Parzialmente in atto**	Beni e dati sono stati elencati, ma la fonte dice che non sono stati classificati del tutto.	Completare la classificazione e usarla per abbinare i controlli alla sensibilità dei dati.	**Alta**

AREA	FOCUS	DOMANDA DI VALUTAZIONE	STATO	PROVE	AZIONE CONSIGLIATA	PRIORITÀ
GDPR: processo sulla privacy	Policy e procedure sulla privacy	Policy, procedure e processi sulla privacy sono documentati e applicati dai dipendenti interessati?	**In atto**	Policy, procedure e processi sulla privacy sono stati sviluppati e vengono applicati.	Mantenere il processo e rivederlo quando l'ambiente cambia.	**Mantenere**
SOC: accesso	Policy di accesso degli utenti	Esistono policy di accesso che danno agli utenti solo l'accesso di cui hanno bisogno?	**Non in atto**	Privilegio minimo e separazione dei compiti non sono applicati; tutti i dipendenti possono accedere ai dati archiviati internamente.	Formalizzare la policy di accesso e applicare permessi basati sul ruolo.	**Critica**
SOC: riservatezza	Riservatezza di PII/SPII	Le informazioni personali sensibili sono mantenute riservate con controlli adeguati di accesso e protezione dei dati?	**Non in atto**	Lo scenario dice che la cifratura non viene usata e che l'accesso interno è troppo ampio.	Limitare l'accesso e introdurre protezioni di riservatezza adeguate.	**Critica**
SOC: integrità	Integrità dei dati	Esistono controlli per mantenere i dati coerenti, completi, accurati e convalidati?	**In atto**	La fonte dice esplicitamente che i controlli sull'integrità dei dati sono presenti.	Mantenere il controllo e continuare a convalidarlo.	**Mantenere**
SOC: disponibilità / autorizzazione	Disponibilità autorizzata	I dati sono disponibili alle persone autorizzate a usarli, senza dare accesso a tutti?	**Non in atto**	I dati sono disponibili, ma l'autorizzazione non è limitata alle persone che ne hanno bisogno per il loro lavoro.	Limitare l'autorizzazione mantenendo la disponibilità per gli utenti legittimi.	**Alta**

07 Cosa emerge

La checklist ha molte righe, ma le stesse poche debolezze continuano a ripresentarsi. È utile, perché significa che Botium Toys non ha bisogno di una soluzione diversa per ogni voce fallita. Poche modifiche scelte bene migliorerebbero più aree insieme.

1. L'accesso è il filo comune

L'assenza di privilegio minimo e di separazione dei compiti non è un problema amministrativo isolato. È il motivo per cui fallisce il controllo PCI DSS sull'accesso, e guida anche i risultati SOC su autorizzazione e riservatezza. Sistemare gli accessi per ruolo migliorerebbe nello stesso momento diverse parti della valutazione.

2. La riservatezza richiede più di una policy

Le procedure sulla privacy esistono, ma i controlli tecnici attorno ai dati sensibili sono più deboli. I dati dei titolari di carta non sono cifrati e l'accesso interno è troppo ampio. Il processo scritto è utile, ma ha bisogno di un'applicazione tecnica più forte.

3. Il ripristino è un vero punto cieco

Niente backup e niente piano di disaster recovery è una combinazione rischiosa. I backup senza un processo di ripristino sono difficili da usare sotto pressione, e un piano di ripristino serve a poco se i dati necessari non esistono. Questi due controlli vanno trattati come un unico problema di ripristino, non come due voci scollegate della checklist.

4. Alcuni controlli esistono, ma sono informali

La policy delle password e il monitoraggio dei sistemi legacy sono due esempi di applicazione parziale. Qualcosa viene fatto, ma il controllo non è ancora abbastanza forte né ripetibile. Queste lacune di solito si chiudono più facilmente di quelle in cui il controllo manca del tutto, perché c'è già un punto di partenza.

5. La base di partenza vale la pena tenerla

L'azienda non parte da zero. Firewall, antivirus, integrità dei dati, procedure sulla privacy, sicurezza fisica e piano di notifica delle violazioni sono già una base solida. Il piano di correzione dovrebbe conservare questi controlli e colmare le lacune su accesso, riservatezza, ripristino e monitoraggio.

08 Ordine di lavoro consigliato

Se dovessi consegnare questa valutazione a un responsabile IT, terrei l'ordine semplice. Si parte dai controlli che riducono direttamente l'esposizione dei dati sensibili e migliorano la capacità di ripristino, poi si passa al monitoraggio e alla maturità dei processi.

PASSO	FOCUS	COSA CAMBIEREI PER PRIMO
1	**Accesso + riservatezza**	Limitare per ruolo l'accesso ai dati sensibili, rafforzare i requisiti delle password e iniziare a cifrare i dati dei titolari di carta e gli altri dati sensibili.
2	**Ripristino**	Creare backup regolari dei dati critici e scrivere un piano di disaster recovery che spieghi come funzionerà davvero il ripristino.
3	**Rilevamento + identità**	Installare un IDS, introdurre la gestione centralizzata delle password e definire la separazione dei compiti per le responsabilità delicate.
4	**Governance + sistemi legacy**	Completare la classificazione dei dati, programmare la manutenzione dei sistemi legacy e documentare cosa succede quando si trova un problema su un sistema legacy.
5	**Nuovo controllo**	Ripetere la valutazione dopo gli interventi e confermare che i controlli funzionano davvero, non solo sulla carta.

Legenda degli stati

STATO	COME L'HO USATO
In atto	La fonte mostra che il controllo esiste e che il suo obiettivo viene raggiunto.
Parzialmente in atto	Il controllo esiste in qualche forma, ma è debole, informale, incompleto o gestito in modo non costante.
Non in atto	Il controllo manca, oppure le prove mostrano che il suo obiettivo non viene raggiunto.

09 Nota finale

Botium Toys ha una base di sicurezza su cui lavorare, ma i controlli non sono equilibrati. Le aree più forti sono perimetro, dispositivi, sicurezza fisica, integrità e una parte del processo sulla privacy. Le più deboli sono autorizzazione, cifratura, ripristino e rilevamento. Questo squilibrio spiega perché il rischio complessivo resta alto anche se diversi controlli sono già presenti.

La parte utile di questo case study non è il numero di caselle fallite, ma il modo in cui le stesse cause ritornano in aree diverse di controlli e conformità. Limitare gli accessi, proteggere i dati sensibili e costruire una vera capacità di ripristino eliminerebbe più risultati in un colpo solo e renderebbe l'ambiente molto più facile da gestire.

Materiali di partenza usati

- Botium Toys: report su ambito, obiettivi e valutazione del rischio
- Checklist di controlli e conformità
- Checklist di controlli e conformità, esempio del corso
- Riferimento sulle categorie di controllo
- Riferimento su ambito e obiettivi dell'audit (usato come esempio di report e di priorità)

Questo case study da portfolio resta entro le prove fornite da quei materiali. Non è un'attestazione formale, una certificazione né una dichiarazione legale di conformità.